



YOU HAVE BEEN HANDED AN AGENT BEHAVIOUR POLICY

A draft behaviour policy for The official Dropbox MCP server.

It tells an agent, in files it can read, what it may do, what it may not, and what actually stands in the way of each thing. It was measured from the deployment rather than copied from a template, and it carries no score: it describes, it does not judge.

TEMPLATE

5 IT CAN DO · 1 WANTED · 4 NOT

0 UNBOUNDED

0 OF 5 MEASURED

4 OPEN QUESTIONS →

new to this? what an ABP is →

01

Read the mandate, and correct it

It is a starting point written to be argued with. Most people authorised less than it assumes — and never mentioned the rest.

02

Give it to your agent

Copy the files into the agent's own context, download them as a zip, or hand over the PDF. Three ways, same files.

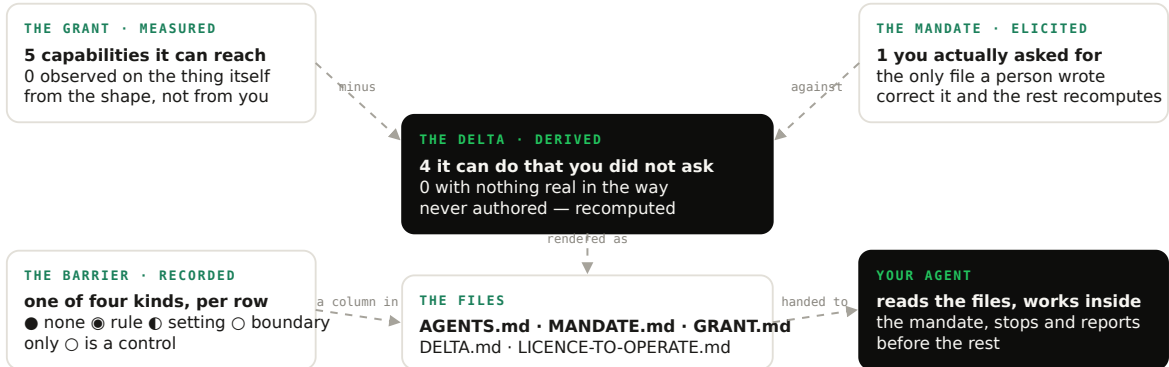
03

Sign the licence to operate

A named person, an interval, nine conditions each beside what enforces it. Until then the agent runs on nobody's say-so.

WHERE THE PIECES GO

Four objects, one route to the agent



Grant minus mandate is the delta. The barrier says what stands in the way of each row. The files carry all four to the agent – and the licence says who authorised it, until when.

THE WHOLE POLICY ON ONE SCREEN

What we want you to do. What we do not.

1 Here is what we want you to do

The mandate. Use these; this is why you were deployed.

read.file.host

irreversible

Read any file the account can reach

1 of 1 wanted capabilities are in the grant. Nothing wanted is missing.

4 Here is what we do not want you to do

The excess: reachable, and not asked for. Each line says what actually enforces it.

delete.file.host

○ a boundary – enforced

Delete files anywhere the account can reach

create.record.world

○ a boundary – enforced

Publish packages, images or pages under the name it holds

authenticate-as.credential.tenant

○ a boundary – enforced

Act in accounts with the credentials it holds

write.file.host

○ a boundary – enforced

Change any file the account can reach

4 of 4 are enforced by a boundary. 0 are only asked — a rule in prose, a setting, or nothing. Those are what the licence accepts with its eyes open, and what a real control would close.

Not the person who made this? Start with the mandate anyway: it is the one file a person wrote, and it is short. Everything else in the vault is derived from it and from the measured grant, and is rebuilt whenever either changes. If you are the agent: read AGENTS.md first. It is written for you.

What an Agent Behaviour Policy is, in five minutes

An Agent Behaviour Policy — ABP for short — is a written description, for one AI agent in one deployment, of everything it can do, what you authorised it to do, the gap between the two, and what actually stands in the way. It is written in files the agent itself can read, so it is both a record for people and an instruction set for the agent.

The problem it answers

When you connect an assistant to a repository, a mailbox, a drive or a cloud account, you know what you asked it to do. Almost nobody knows what it can do: the credential it runs on usually permits far more than the task needed, and nobody wrote that down. If the agent then does something you did not want, the first question you will be asked is what you did authorise. This document is the answer to that question, written before it is asked.

Four words, and the verb attached to each is the whole model

MEASURED

The grant

Everything the agent can actually reach — files, processes, credentials, network, repositories, schedules — measured from the deployment shape, not from your account and not by asking the agent.

ELICITED

The mandate

What you wanted it to do. You already know this; it is the one part a person writes. In a template it is a starting point, deliberately conservative, written to be corrected upward.

DERIVED

The delta

The grant minus the mandate: what it can do that you did not ask for. Never written by hand — recomputed whenever the grant or the mandate changes.

RECORDED

The barrier

For each capability, what stands in the way: nothing, a rule in prose, a setting the agent could flip, or a boundary enforced above it. Only the last one is a control.

Why there is no score

Every reader asks for one. The same policy is harmless where nothing valuable is reachable and dangerous with a production database attached tomorrow — and nothing about the document changed. A score needs the assets and the consequences, and this document has neither. It describes; a risk assessment, built on top of it, judges.

What it is not

- Not a guardrail: the files ask, the barrier column says what enforces.
- Not a compliance assessment, a certification or an audit of any product.
- Not a template: it is derived from one deployment shape, and a copy is corrected for yours.

What to do with this vault

- **If you run this agent:** read the mandate, correct it, give the files to the agent, and sign the licence. The three buttons on Start here are those steps.
- **If you were sent this by someone who runs it:** the Start here view is the whole policy on one screen; the Delta view is the part worth a conversation.
- **If you are the agent:** read AGENTS.md first. It is written for you.

The model, the vocabulary and the worked examples are public: riskmandate.ai/abp explains how it is sold and used; abp.sgit.ai holds the 23 capability primitives, the four barriers and the published deployment shapes this vault was computed against (v0.3.0).

The official Dropbox MCP server

For one agent in one deployment: everything it can do, what you authorised, the gap between the two, and what actually stands in the way.

TEMPLATE

The official Dropbox MCP server

The official Dropbox MCP server · grant 2026-09-15 · mandate 2026-09-15 · as at 2026-09-15

5

capabilities in the grant

1

wanted by the mandate

4

excess — granted, not asked for

0

unbounded — nothing in the way

0 of 5 rows measured 0 shortfall 1 aligned as stored in the vault

excess, by barrier



☐ none ☒ expectation ☐ setting ☐ boundary — the only control

Looking for a score? There is none, on purpose. This document describes what the agent can do and what you asked for; it does not judge whether that is acceptable, because the same policy is harmless in one deployment and dangerous in another. The number you can move is the unbounded excess, and only a real control moves it.

The mandate, in one paragraph

I connected Dropbox so the assistant could find and read my files. I did not want it creating links anyone can open, and I did not want it deleting or moving anything.

Elicited — starting-point, authored 2026-09-15. The only authored file in this vault.

The deployment

Dropbox's own MCP server, connected from an MCP client with a Dropbox app configured for scoped access and eight permissions: account_info.read,

files.metadata.read, files.content.read, files.content.write, sharing.read, sharing.write, file_requests.read, file_requests.write. The rows are its published tool list read as capabilities. "If you change your Dropbox app settings, such as adding a new scope, you must reconnect" — the scope set is the boundary, and it is the whole of it: there is no folder-scoped variant.

Dropbox · surface mcp · widest reach world

Four objects, and the verb attached to each

- **The mandate is elicited.** What the agent is authorised and expected to do — you already know it.
- **The grant is measured.** Everything the agent can do, from the shape, the account and the credentials.
- **The delta is derived.** Recomputed whenever either input moves; never edited by hand.
- **The barrier is recorded.** Per row, one of four kinds — and only the fourth is a control.

Validity

This describes the deployment shape as at this date. If the risk changed, the deployment changed — not this document.

- the grant version changes — a product release, a setting, a connector enabled or removed
- the mandate changes — the deployer authorises more or less
- the vocabulary version changes — a primitive is added, split or renamed
- a barrier moves — a setting becomes a boundary, or a boundary is removed

Delivered as an encrypted vault. This page is a little HTML on top of the files beside it, rendered straight from them. Anyone holding the read key can check every number here against the bytes it came from; the write side stays with the owner.

Everything the agent can do

5 capabilities, 0 measured. Irreversible rows first. Every row says how it is known, what stands in the way, and whether the effect can be undone.

CAPABILITY	WHAT IT IS	BARRIER	UNDO	EVIDENCE	
read.file.host	Read any file the account can reach	 boundary	no	documented	(C S I I C)
delete.file.host	Delete files anywhere the account can reach	 boundary	no	documented	I
create.record.world	Publish packages, images or pages under the name it holds	 boundary	no	documented	(C C)
authenticate-as.credential.tenant	Act in accounts with the credentials it holds	 boundary	no	documented	V C
write.file.host	Change any file the account can reach	 boundary	with-effort	documented	(C C C)

Whose material is not in the published grammar. It is the property a connector shape needs — own, organisation, third_party or mixed — asked of the model site as Lab 03 request 1. Mixed is the finding: no setting these vendors offer makes it own.

4 open questions — needs research

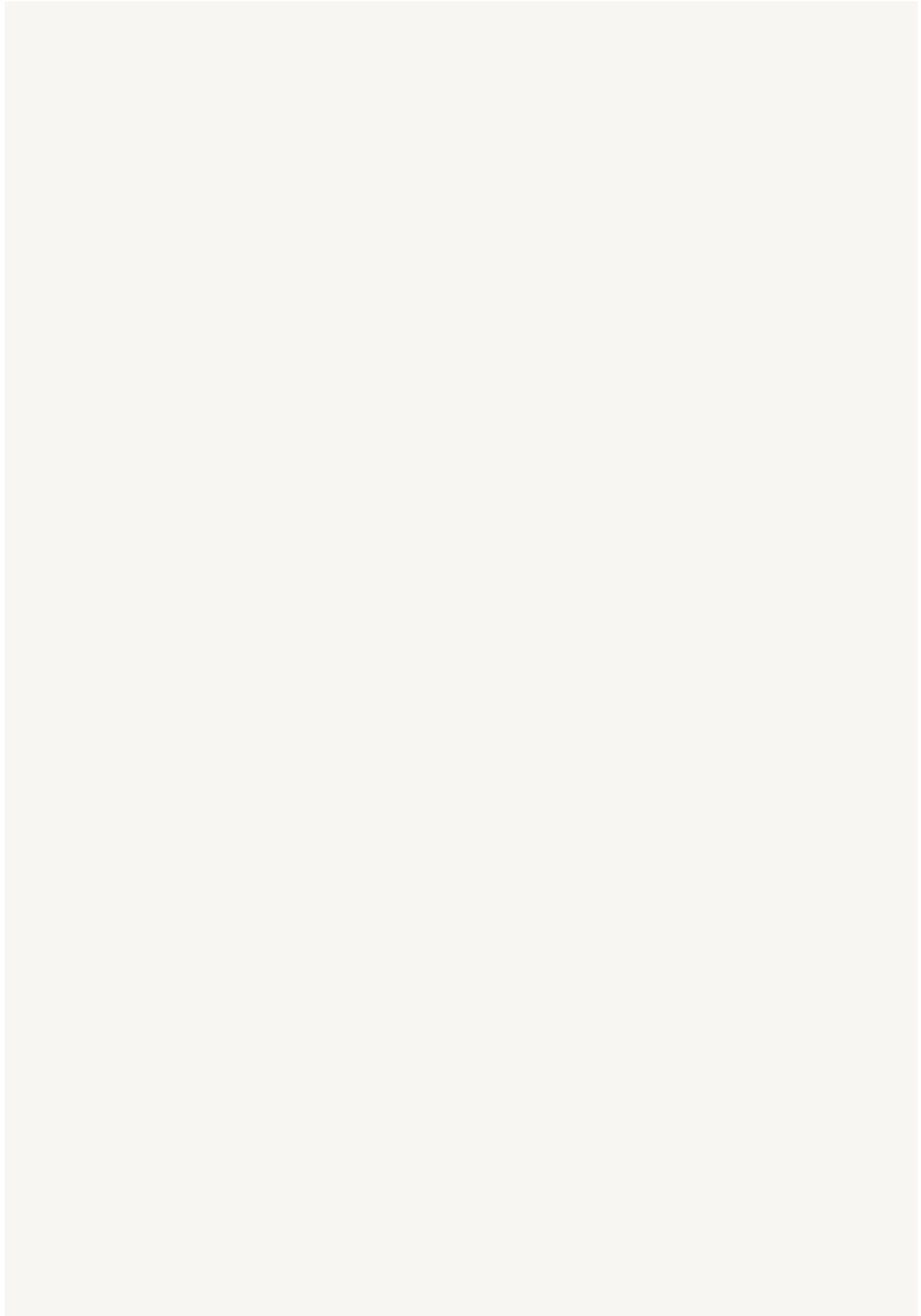
What this grant cannot settle from the pages it was read from. Each row stands at the evidence tier shown until its question is answered — from the vendor's own pages or a system you are entitled to run, never by probing somebody else's. RESEARCH-NEEDED.md in this vault is written to be handed to an agent.

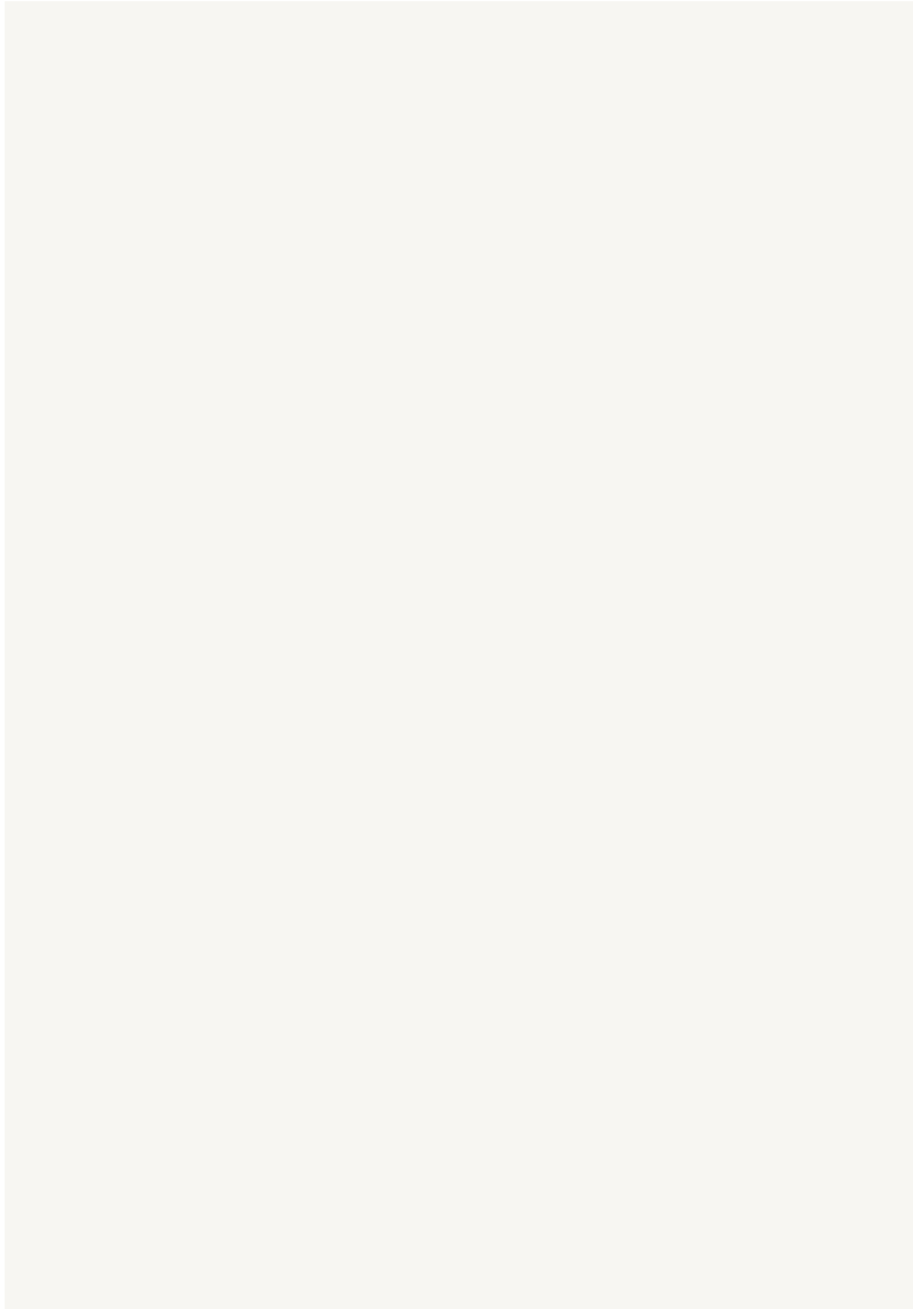
1. **create.record.world** — What is the default audience of a link CreateSharedLink makes — anyone with the link, or the team? GetSharedLinkMetadata reports an audience, so one is set. · Dropbox's API reference for sharing/create_shared_link_with_settings and its default link_audience, quoted.
2. **delete.file.host** — What is the recovery window per plan, and does Basic have one at all? · Dropbox help on version history and file recovery, per plan.
3. **authenticate-as.credential.tenant** — Can a team administrator block or restrict this MCP app for the whole team, and what is the default? · Dropbox App Center administration help.
4. **write.file.host** — Does files.content.write permit changing an existing file's content in place, or only creating, copying and moving? · The scope description on Dropbox's developer pages; CreateFile says "Create a new".

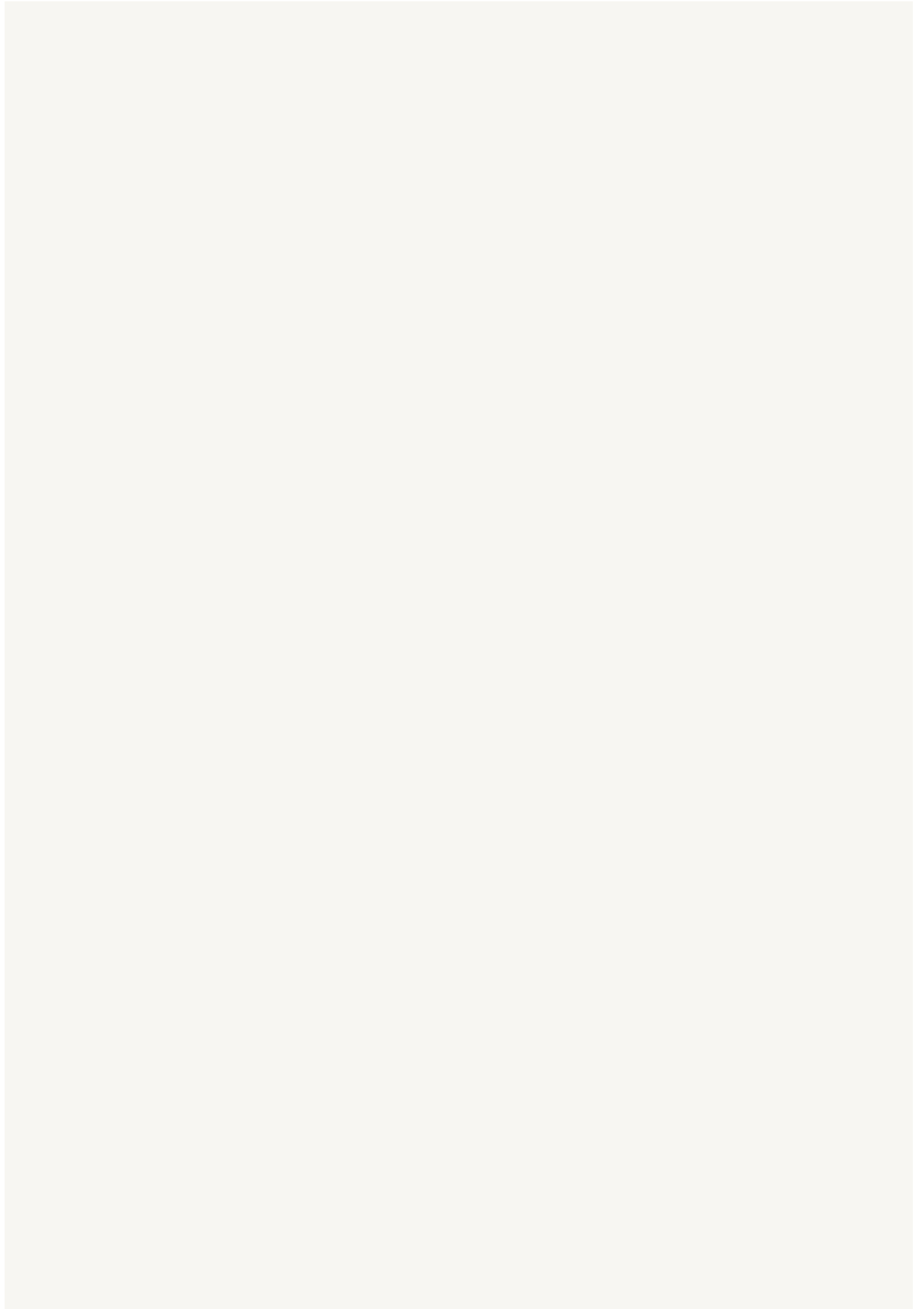
Where the vendor's own pages disagree

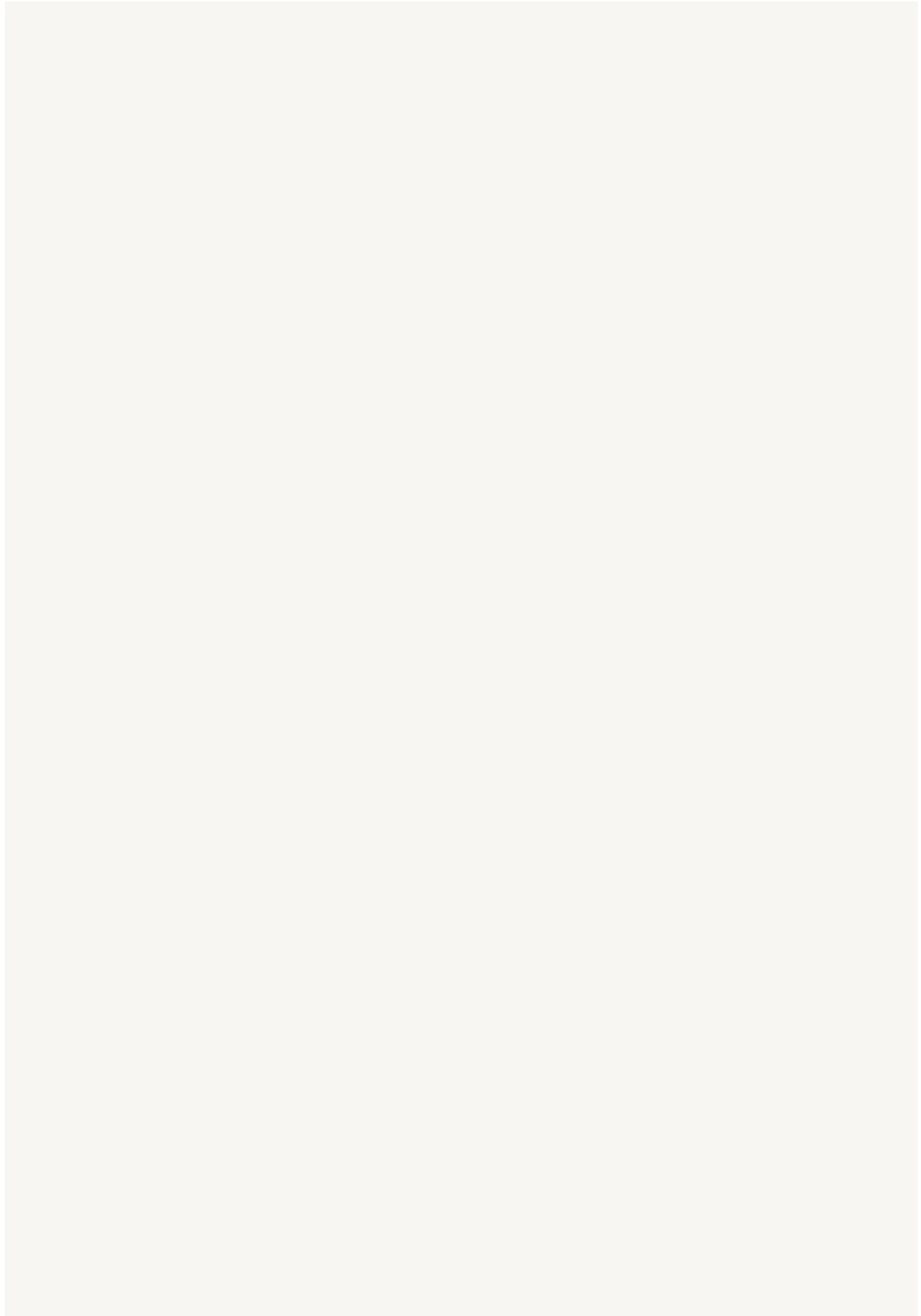
Advertised in one place, permitted in another. Published unresolved on purpose; if the vendor says which page is right, this changes and says so.

WHAT IS ADVERTISED	WHAT THE GRANT PERMITS	STATE
"Files aren't deleted permanently."	"Recovery depends on your plan's recovery window." — the same tool description; after the window they are gone	unresolved
"Support files up to 5 MB" (GetFileContent)	DownloadLink: "download the original file instead of reading extracted text" — the limit is on extraction, not on reach	unresolved









RiskMandate — Agent Behaviour Policy, delivered as a vault. Grant 2026-09-15 · mandate 2026-09-15 · vocabulary abp.sgit.ai v0.3.0 · as at 2026-09-15. It describes and it does not judge, so it carries no score. Not a compliance assessment, a certification, an audit or a security review of any named product. CC BY 4.0. riskmandate.ai · abp.sgit.ai